

KESTRELATTICE

Governed Agent Mesh | Micro-Product

Agent Sandboxing Vendor Scorecard

Score sandbox and isolation vendors on escape resistance and audit visibility. A complete, zero-placeholder draft for teams governing AI agents in production: policy gates, audit trails, cost controls, permissioning, and incident response, written so you can adopt it as-is.

A complete, ready-to-use governance document. Adopt it as-is, customize the bracketed fields to your environment, and put it to work today.

Instant delivery | Yours to keep, forever.

Agent Sandboxing Vendor Scorecard

For Buyers Governing AI Agents in Production

Introduction

This scorecard evaluates **AI agent sandboxing vendors**--solutions designed to isolate, monitor, and govern AI agents in production environments. A robust sandboxing layer is critical for mitigating risks like data leakage, adversarial attacks, cost spirals, and compliance violations. This document assesses vendors across **policy enforcement, auditability, cost controls, permissioning, and incident response**--key dimensions of production-grade AI governance.

1. Policy Enforcement & Guardrails

Objective: Ensure agents adhere to organizational policies before interacting with production systems.

Criteria	Evaluation Metrics	Vendor Response
Policy Definition	Does the vendor support customizable policy rules (e.g., forbidden APIs, data patterns, hallucination thresholds)?	[x] Yes (supports YAML/JSON-based definitions with regex, NLP rules, and context-aware constraints)
Dynamic Policy Updates	Can policies be pushed in real-time without agent redeployment?	[x] Yes (supports live policy updates via API or config reload)
Policy Enforcement	Does enforcement block or log violations? If blocked, is there a fallback mechanism (e.g., degraded mode)?	[x] Blocks violations with configurable fallback (e.g., "deny with explanation" or "redirect to human review")
Policy Exceptions	Can exceptions be granted per-agent, per-task, or per-user with audit trails?	[x] Yes (fine-grained RBAC with justification logging)
Third-Party Policy Sync	Can policies be synced with external sources (e.g., compliance databases, internal SIEM)?	[] No (but supports manual export/import for integration)

Scoring: 9/10 (Policy flexibility is high, but third-party sync is limited.)

2. Auditability & Transparency

Objective: Ensure full visibility into agent behavior for compliance and forensics.

Criteria	Evaluation Metrics	Vendor Response
Event Logging	Are all agent actions logged (inputs, outputs, API calls, policy violations)?	[x] Yes (structured logs with timestamps, agent ID, user context, and policy references)

Criteria	Evaluation Metrics	Vendor Response
Immutable Audit Trail	Are logs writable-once (e.g., blockchain-like hashing or WORM storage)?	☒ Yes (logs signed with cryptographic hashes; immutable storage via S3 + CloudTrail)
Queryable Audit Data	Can logs be filtered by time, agent, user, or policy ID?	☒ Yes (via SQL-like query interface or API)
Third-Party Access	Can logs be exported to SIEM/GRC tools (e.g., Splunk, Datadog, ServiceNow)?	☒ Yes (OpenSearch-compatible exports, REST API for ingestion)
Agent Explanation	Does the vendor provide post-hoc explanations for agent decisions?	☒ Yes (LLM-generated rationales + rule-based triggers for policy violations)

Scoring: 10/10 (Audit trail is production-grade with export flexibility.)

3. Cost Controls & Resource Management

Objective: Prevent runaway spending on AI agent execution.

Criteria	Evaluation Metrics	Vendor Response
Token/Execution Limits	Can per-agent, per-user, or per-task limits be set (e.g., max tokens, runtime)?	☒ Yes (hard limits + soft quotas with alerts)
Cost Monitoring	Is there real-time cost tracking (e.g., per-prompt pricing, API call costs)?	☒ Yes (dashboards + alerts for threshold breaches)
Auto-Shutdown	Can agents be automatically terminated if limits are exceeded?	☒ Yes (configurable timeout + budget-based kill switches)
Multi-Cloud Cost Data	Does the vendor aggregate costs across cloud providers (e.g., AWS, GCP, Azure)?	☐ No (requires manual aggregation)
Cost Recovery	Can the vendor reimburse overages if a misconfiguration causes excessive spend?	☐ No (but offers pre-approval workflows for high-risk tasks)

Scoring: 8/10 (Strong cost controls, but multi-cloud aggregation is missing.)

4. Permissioning & Access Control

Objective: Ensure only authorized users/agents interact with sensitive systems.

Criteria	Evaluation Metrics	Vendor Response
Role-Based Access	Does the vendor support RBAC (e.g., admin, auditor, developer, end-user roles)?	☒ Yes (with granular permissions per policy, audit, and cost controls)

Criteria	Evaluation Metrics	Vendor Response
Just-In-Time (JIT) Access	Can access be temporarily granted (e.g., for MFA-approved ad-hoc tasks)?	[x] Yes (via API or CLI with ephemeral credentials)
Least Privilege	Are agents scoped to minimal required permissions by default?	[x] Yes (default "deny-all" with explicit allowlists)
Multi-Factor Auth (MFA)	Is MFA required for sensitive operations (e.g., policy changes, cost overrides)?	[x] Yes (via SAML/OAuth 2.0 with MFA enforcement)
Zero-Trust Integration	Does the vendor integrate with IAM/SSO (e.g., Okta, Azure AD, Ping Identity)?	[x] Yes (via OAuth 2.0, SCIM, and custom SAML connectors)

Scoring: 10/10 (Zero-trust-ready with fine-grained access controls.)

5. Incident Response & Containment

Objective: Ensure rapid mitigation of agent misbehavior or security incidents.

Criteria	Evaluation Metrics	Vendor Response
Automated Containment	Can agents be sandboxed or killed on policy violation or anomaly detection?	[x] Yes (real-time containment with configurable triggers)
Incident Playbooks	Does the vendor provide predefined response templates (e.g., data breach, cost spike)?	[x] Yes (via integrations with PagerDuty/ServiceNow)
Forensic Capture	Can snapshots of agent state be taken for post-incident analysis?	[x] Yes (memory dumps, execution traces, and input/output history)
Vendor Support SLA	What is the response time for critical incidents (e.g., data leakage)?	[x] 15-minute response for P1 incidents (SLA documented)
Third-Party Alerts	Can incidents trigger external alerts (e.g., Slack, email, SIEM)?	[x] Yes (webhook-based notifications)

Scoring: 10/10 (End-to-end incident response with forensic capabilities.)

6. Security & Compliance

Objective: Ensure the sandboxing vendor itself is secure and compliant.

Criteria	Evaluation Metrics	Vendor Response
Data Residency	Can agent data be kept in specific regions (e.g., EU, US Gov Cloud)?	[x] Yes (multi-region deployment with data locality controls)

Criteria	Evaluation Metrics	Vendor Response
Encryption	Is agent communication and logs encrypted in transit and at rest?	[x] Yes (TLS 1.3 + AES-256 for data at rest)
Compliance Certifications	Does the vendor hold ISO 27001, SOC 2 Type II, or HIPAA/BaaS compliance?	[x] Yes (ISO 27001 certified; SOC 2 Type II in progress)
Vendor Risk Assessment	Has the vendor undergone third-party security audits (e.g., Penetration Testing)?	[x] Yes (Annual SOC 2 audit + quarterly vulnerability scans)
Vendor Lock-in	Can agent configurations be exported/imported to another sandboxing vendor?	[] No (proprietary format, but supports API-based data migration)

Scoring: 9/10 (Strong security posture, but vendor lock-in is a minor concern.)

7. Performance & Scalability

Objective: Ensure the solution can handle production workloads efficiently.

Criteria	Evaluation Metrics	Vendor Response
Latency	What is the average latency for policy enforcement in high-throughput scenarios?	[x] <100ms for 95th percentile (benchmarked at 10K RPS)
Horizontal Scaling	Does the vendor support auto-scaling for peak loads?	[x] Yes (Kubernetes-based deployment with HPA)
Agent Isolation	Are agents fully isolated (no shared state between tasks)?	[x] Yes (ephemeral containers per invocation)
Cold Start Mitigation	Does the vendor pre-warm agents to reduce cold-start latency?	[x] Yes (configurable warm-up pools for critical agents)
Multi-Tenant Isolation	Is there strong isolation between tenants (e.g., no cross-tenant data leakage)?	[x] Yes (VPC peering, network policies, and tenant-specific storage)

Scoring: 10/10 (Production-ready performance with strong isolation guarantees.)

8. Pricing & Total Cost of Ownership (TCO)

Objective: Assess long-term cost implications.

Criteria	Evaluation Metrics	Vendor Response
Pricing Model	Is pricing per-agent, per-invocation, or usage-based?	[x] Usage-based (pay per policy evaluation, log storage, and API call)
Free Tier	Does the vendor offer a free tier or trial?	[x] Yes (10K monthly policy evaluations free; 30-day trial for enterprise)

Criteria	Evaluation Metrics	Vendor Response
Hidden Costs	Are there additional fees for premium features (e.g., advanced auditing)?	☐ No (all features included in tiered pricing)
Economies of Scale		

KESTRELATTICE

The governed agent mesh for production AI.

kestrelattice.com